

Assessment Advanced Cybersecurity Concepts

Section A – Scenario-Based Concept Application

Q1. Verification: Explain the multi-factor verification process used to distinguish a legitimate password reset from a credential harvesting attempt.

Answer:

- Multi-Factor Authentication (MFA) verifies the user's identity using more than one factor, such as a password and OTP or biometric verification.
- During a legitimate password reset, the website asks for MFA before allowing access.
- Credential harvesting pages usually collect only the username and password without proper verification, making them suspicious.

Q2. Header Analysis: Identify the specific metadata fields in an SMTP header that reveal a mismatch between the 'Sender' and 'Reply-To' addresses.

Answer:

The important SMTP header fields are:

- From
- Sender
- Reply-To
- Return-Path

If the Reply-To address is different from the From or Sender address, it may indicate a phishing email.

Q3. Spoofing Logic: Explain how "display name spoofing" can successfully deceive users even when the underlying domain passes SPF/DKIM checks.

Answer:

- Display name spoofing uses a trusted person's name, such as "HR Team" or "CEO", while the actual email address belongs to the attacker.
- Even if SPF and DKIM pass, users may trust the display name and click the malicious link.

Q4. Defense-in-Depth: Describe the strategic role of user awareness training as a "human firewall" in conjunction with technical email filtering.

Answer:

- User awareness training teaches employees how to identify phishing emails, suspicious links, and fake attachments.
- Technical email filters block many attacks, while trained users can stop attacks that bypass security systems. Together they provide better protection.

Assessment Advanced Cybersecurity Concepts

Q5. Incident Response: Outline the immediate sequence of host isolation and credential revocation required once a malicious link is confirmed clicked.

Answer:

1. Disconnect the infected computer from the network.
2. Disable or reset the compromised account.
3. Revoke active user sessions and tokens.
4. Scan the system for malware.
5. Change passwords and enable MFA.
6. Monitor logs for suspicious activity.

Q6. Framework Mapping: Identify the NIST Cybersecurity Framework (CSF) category that mandates organizational training to mitigate social engineering risks.

Answer:

- The correct NIST CSF category is:
- Protect (PR) → Security Awareness and Training (PR.AT)
- This category focuses on training employees to recognize and prevent phishing and other social engineering attacks.

Section B – Practical Application

Q1. Simulation: Use the Social Engineering Toolkit (SET) to generate a credential harvester template targeting a simulated corporate login.

Answer:

Steps:

1. Open Terminal.
2. Run `sudo setoolkit`
3. Select Social Engineering Attacks
4. Select Credential Harvester Attack Method
5. Select Site Cloner
6. Enter the target login page URL.
7. Start the local web server.

Assessment Advanced Cybersecurity Concepts

Q2. Forensics: Open a raw .eml file in a text editor to locate the originating IP and check it against known blacklists via CLI.

Answer:

Steps:

1. Open the .eml file using a text editor.
2. Find the Received: header.
3. Identify the originating IP address.
4. Check the IP using:

whois <IP_Address>

or

host <IP_Address>

Then verify the IP using MXToolbox blacklist checker.

Q3. DNS Validation: Use dig or nslookup to verify the presence of SPF and DMARC "p=reject" policies for a given domain.

Answer:

Check SPF:

dig TXT example.com

or

nslookup -type=TXT example.com

Check DMARC:

dig TXT _dmarc.example.com

If the record contains:

v=DMARC1; p=reject;

then the domain has a reject policy enabled.

Q4. Log Identification: Parse a provided proxy log to identify successful HTTP POST requests made to a non-standard external domain.

Answer:

Search the proxy logs for:

- HTTP Method = POST
- Status Code = 200
- Unknown external domain

These entries may indicate data exfiltration or credential submission.

Assessment Advanced Cybersecurity Concepts

Q5. Mitigation: Configure a Mail Flow rule in a simulated environment to prepend a "Warning: External Email" banner to all incoming messages.

Answer:

Steps:

1. Open Mail Flow Rules.
2. Create a new transport rule.
3. Apply the rule to external emails.
4. Add the banner:

Warning: External Email

5. Save and enable the rule.

Section C – Integrated Case Study

Q1. Detection: Based on the symptoms, identify the specific indicators that suggest a session token was stolen rather than just a password.

Answer:

Indicators include:

- Successful login after MFA without a new MFA prompt.
- Access from an unusual location or device.
- Continuous authenticated sessions after password change.
- Unauthorized access to sensitive data.

Q2. Containment: Outline the precise steps to revoke all active refresh tokens for the compromised user to terminate the attacker's access.

Answer:

1. Disable the compromised account.
2. Revoke all refresh and access tokens.
3. Force user sign-out from all devices.
4. Reset the password.
5. Re-enable MFA.
6. Monitor account activity.

Assessment Advanced Cybersecurity Concepts

Q3. Framework Alignment: Map this incident to the NIST "Respond" (RS.RP) category and list two required actions to document the event.

Answer:

Category: Respond (RS.RP) – Response Planning

Required actions:

1. Document the incident details.
2. Record response actions and lessons learned for future improvement.

Q4. Technical Solution: Propose a phishing-resistant authentication method (e.g., FIDO2/WebAuthn) that would have blocked this proxy-based attack.

Answer:

Use FIDO2/WebAuthn Security Keys. These use public-key cryptography and verify the website's domain, preventing attackers from stealing passwords or session tokens through phishing proxies.

Q5. Policy Design: Suggest one automated technical control to restrict account logins to only company-managed, compliant devices.

Answer:

Implement Conditional Access Policies with device compliance checks. Only company-managed and compliant devices are allowed to access corporate resources, reducing unauthorized access.